

Guia de Enumeração e Vetores de Ataque

1. Vetor SMB e RPC (Portas 139, 445, 135)

- **Contexto:** Compartilhamento de arquivos e mapeamento de endpoints do Windows/Samba. Geralmente é o vetor primário para coleta de informações não autenticadas na rede interna.
- **Ações:** Enumeração de sessões nulas (Null Session), coleta de políticas de senha do domínio, extração da lista de usuários (RID cycling) e busca por compartilhamentos ocultos.
- **Comandos úteis:**

```
smbclient -L //IP_DO_ALVO/ -N
enum4linux -a IP_DO_ALVO
crackmapexec smb IP_DO_ALVO --shares -u '' -p ''
rpcclient -U "" -N IP_DO_ALVO
```
- **O que buscar:** Compartilhamentos (shares) liberados para "anonymous" ou permissões mal configuradas no IPC\$ e print\$. Buscar arquivos .bak, scripts de deploy (.bat, .ps1) que contenham senhas hardcoded, ou wordlists deixadas pela administração.
- **Vulnerabilidades Comuns:** EternalBlue (MS17-010 / CVE-2017-0144), SMBGhost (CVE-2020-0796), SambaCry (CVE-2017-7494). Falta de assinatura SMB (SMB Signing not required), permitindo ataques de Relay (NTLM Relay).

2. Vetor Web e CMS (Portas 80, 443, 8080)

- **Contexto:** A porta da frente. Hospeda sites institucionais, webmails, sistemas de intranet ou painéis administrativos em tecnologias legadas.
- **Ações:** Mapeamento da superfície de ataque (fuzzing de diretórios, subdomínios), identificação rigorosa da stack (frameworks, plugins) e análise de parâmetros visíveis e invisíveis.
- **Comandos úteis:**

```
ffuf -w wordlist.txt -u http://IP_DO_ALVO/FUZZ
nikto -h http://IP_DO_ALVO
wpscan --url http://IP_DO_ALVO -e u,vp
```

- **O que buscar:** Backups de arquivos de configuração (`.env` , `wp-config.php.bak`), listagem de diretórios (Directory Listing), painéis de administração desprotegidos. Testar bypass de autenticação e falhas de Injeção (SQLi, LFI, RFI).

3. Vetor FTP (Porta 21)

- **Contexto:** Protocolo clássico e em texto claro (cleartext), comumente negligenciado.
- **Ações:** Tentar login anônimo. Checar capacidade de upload (comando PUT) nos diretórios e identificar a versão do daemon FTP.
- **Comandos úteis:**
`ftp IP_D0_ALVO` (Testar user 'anonymous' com senha em branco)
`nmap -p 21 --script ftp-anon,ftp-syst IP_D0_ALVO`
- **O que buscar:** Chaves de acesso (como `id_rsa`), backups inteiros do servidor web, arquivos do sistema operacional. Se houver permissão de escrita e o diretório refletir no servidor Web, é possível subir uma reverse shell (Webshell) em PHP/ASP.
- **Vulnerabilidades Comuns:** vsftpd 2.3.4 Backdoor (CVE-2011-2523), ProFTPD 1.3.5 Mod_Copy (CVE-2015-3306), permitindo cópia de arquivos críticos sem autenticação.

4. Vetor SSH (Porta 22)

- **Contexto:** Serviço de administração segura. Raramente é o ponto de entrada direto via exploit, a menos que versões antigas estejam rodando, mas é alvo frequente de testes de senhas vazadas.
- **Ações:** Banner grabbing, enumeração passiva de usuários e brute-force focado com listas de palavras geradas a partir de metadados do alvo.
- **Comandos úteis:**
`ssh-keyscan IP_D0_ALVO`
`hydra -l USUARIO -P senhas_coletadas.txt ssh://IP_D0_ALVO`
- **O que buscar:** Login direto como `root` ativado, uso de chaves criptográficas sabidamente fracas (como a falha de PRNG do Debian).

- **Vulnerabilidades Comuns:** OpenSSH User Enumeration (CVE-2018-15473) — excelente técnica para confirmar se os usuários encontrados no SMB ou em e-mails realmente existem no sistema Linux.

5. Vetor E-mail: SMTP, POP3 e IMAP (Portas 25, 110, 143)

- **Contexto:** O backend de e-mail. Interfaces web interagem com eles. O foco direto nos protocolos costuma render extração de usuários ou encaminhamento de tráfego.
- **Ações:** Interagir com o SMTP para verificar contas via comandos VRFY e EXPN. Conectar no POP3/IMAP usando credenciais fracas.
- **Comandos úteis:**
 - `telnet IP_DO_ALVO 25` (Interação manual, usar `VRFY admin`)
 - `nmap -p 25 --script smtp-enum-users IP_DO_ALVO`
- **O que buscar:** Relays abertos (Open Relay), que permitem falsificar e-mails e enviar spear-phishing interno. Ao acessar caixas postais, buscar resets de senha automáticos, relatórios de cronjobs com comandos explícitos e conversas de TI.

6. Vetor SNMP (Portas 161 e 162 UDP)

- **Contexto:** Monitoramento de rede. É uma mina de ouro de informações, especialmente versões v1 e v2c que não possuem criptografia.
- **Ações:** Fazer a varredura na árvore OID usando community strings padrão.
- **Comandos úteis:**
 - `snmpwalk -c public -v 2c IP_DO_ALVO`
 - `onesixtyone -c dict.txt IP_DO_ALVO`
- **O que buscar:** Comandos em execução passando senhas via terminal (ex: `mysql -u root -pSenhaSecreta`), tabelas de roteamento, portas internas mapeadas que não saem no scan externo (Nmap), e lista de softwares instalados.

7. Vetor Banco de Dados: MySQL e PostgreSQL (Portas 3306, 5432)

- **Contexto:** Armazenamento da aplicação. Se expostos ou alcançáveis pós-comprometimento de máquina pivô, abrem brecha direta para execução remota.
- **Ações:** Brute force de usuários padrão e exploração de privilégios de superusuário (DBA).
- **Comandos úteis:**

```
mysql -h IP_DO_ALVO -u root -p
psql -h IP_DO_ALVO -U postgres
```
- **O que buscar e Vulnerabilidades:**
 - **MySQL/MariaDB:** Com permissões altas, é possível usar User Defined Functions (UDF) para carregar uma biblioteca .so/.dll maliciosa e ganhar execução de comandos (RCE) no SO subjacente.
 - **PostgreSQL:** Possui LFI nativo usando `pg_read_file()`. Em versões acima da 9.3, o comando `COPY FROM PROGRAM` permite RCE direto sem precisar compilar bibliotecas externas.

8. Vetor AD: LDAP e WinRM (Portas 389, 636, 5985, 5986)

- **Contexto:** A base do Active Directory em ambientes corporativos Windows.
- **Ações (LDAP):** Explorar Null Bind ou autenticar com usuário de baixo privilégio para extrair todo o mapa do domínio (usando SharpHound/BloodHound).
- **Ações (WinRM):** Ferramenta de gerenciamento remoto do Windows. Na posse de credenciais administrativas, provê uma shell estável de imediato, dispensando exploração via SMB.
- **Comandos úteis:**

```
ldapsearch -x -H ldap://IP_DO_ALVO -b "dc=dominio,dc=local"
evil-winrm -i IP_DO_ALVO -u USUARIO -p SENHA
```
- **Ataques Comuns:** Kerberoasting (coleta de SPNs via LDAP), AS-REP Roasting e Pass-the-Hash via WinRM.